

How Far Are We from Automatically Identifying Violations of the Data Minimization Principle in Privacy Policies?

Ziyan Zhou

Institute of Information Engineering,
Chinese Academy of Sciences
School of Cyber Security, University
of Chinese Academy of Sciences
State Key Laboratory of Cyberspace
Security Defense
Beijing, China
zhouziyan@iie.ac.cn

Yanru He*

Institute of Information Engineering,
Chinese Academy of Sciences
State Key Laboratory of Cyberspace
Security Defense
Beijing, China
heyianru@iie.ac.cn

Yunchuan Guo

Institute of Information Engineering,
Chinese Academy of Sciences
School of Cyber Security, University
of Chinese Academy of Sciences
State Key Laboratory of Cyberspace
Security Defense
Beijing, China
guoyunchuan@iie.ac.cn

Haoyang Yu

Institute of Information Engineering,
Chinese Academy of Sciences
School of Cyber Security, University
of Chinese Academy of Sciences
State Key Laboratory of Cyberspace
Security Defense
Beijing, China
yuyaoyang@iie.ac.cn

Liang Fang

Institute of Information Engineering,
Chinese Academy of Sciences
State Key Laboratory of Cyberspace
Security Defense
Beijing, China
fangliang@iie.ac.cn

Fenghua Li

Institute of Information Engineering,
Chinese Academy of Sciences
School of Cyber Security, University
of Chinese Academy of Sciences
State Key Laboratory of Cyberspace
Security Defense
Beijing, China
lifenghua@iie.ac.cn

Abstract

Data protection laws and regulations require service providers to disclose data practices in privacy policies, specifying what personal information is processed and for what purposes. For compliance, these data practices must adhere to the *data minimization principle*, limiting the processing of personal information to what is directly relevant and necessary for the service purposes. However, data minimization is context-dependent, making violations difficult to define and quantify in privacy policies. Meanwhile, privacy policies are semantically complex and unstructured, hindering accurate extraction of fine-grained data practices and large-scale automated evaluation. To address these issues, we propose *DataMini*, a human-LLM collaborative evaluation framework for identifying violations of the data minimization principle in privacy policies. First, *DataMini* categorizes data minimization violations into two dimensions: *inherent violations* and *contextual violations*, establishing fine-grained evaluation criteria. Second, we construct a compliance baseline by mining high-frequency patterns from large-scale privacy policies and integrating expert knowledge to derive compliance mappings for human-LLM collaborative evaluation. Finally, the compliance baseline can automatically verify data practices that satisfy the data minimization principle, enabling the framework to focus exclusively on identifying suspected violations to improve efficiency

and accuracy. Extensive evaluations demonstrate that *DataMini* exhibits superior data practice extraction accuracy of 83.46% and achieves an F1-score of 0.8180 for identifying data minimization violations in privacy policies, reducing manual evaluation effort by approximately 80%.

CCS Concepts

• **Security and privacy** → **Privacy protections**; *Web application security*; • **Human-centered computing** → **Human computer interaction (HCI)**.

Keywords

Data Minimization Principle, Privacy Policy, Compliance Evaluation, Retrieval-augmented Generation

ACM Reference Format:

Ziyan Zhou, Yanru He, Yunchuan Guo, Haoyang Yu, Liang Fang, and Fenghua Li. 2026. How Far Are We from Automatically Identifying Violations of the Data Minimization Principle in Privacy Policies?. In *Proceedings of the 49th International ACM SIGIR Conference on Research and Development in Information Retrieval (SIGIR '26)*, July 20–24, 2026, Melbourne, VIC, Australia. ACM, New York, NY, USA, 11 pages. <https://doi.org/10.1145/3805712.3809572>

1 Introduction

Privacy policies are legally binding, user-facing documents used to disclose **how** service providers process user data, **what** specific types of data are involved, and **why** such data processing activities are conducted. In practice, these specific operations performed on user information for providing certain services, as described in privacy policies, are referred to as **data practices** [30], which can be formally represented as triples of the form (a, d, p) , where a , d , and

*Yanru He is the corresponding author.



This work is licensed under a Creative Commons Attribution 4.0 International License. *SIGIR '26, Melbourne, VIC, Australia*

© 2026 Copyright held by the owner/author(s).

ACM ISBN 979-8-4007-2599-9/2026/07

<https://doi.org/10.1145/3805712.3809572>

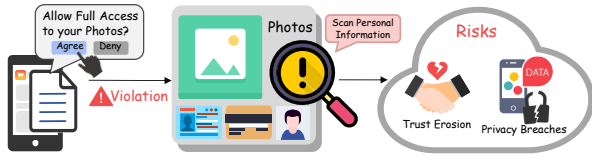


Figure 1: Potential harms of data minimization violations. The app requests full photo album access for recommendations, violating the data minimization principle, which increases the risk of privacy breaches and erodes user trust.

p represent the action, data type, and purpose, respectively. As privacy policies are the primary medium for users to understand these practices, influential regulations such as the *General Data Protection Regulation (GDPR)* [1], *California Privacy Rights Act (CPRA)* [2], and *Personal Information Protection Law (PIPL)* [3] establish guiding principles to regulate the content of privacy policies. Among these, the data minimization principle is crucial for personal data protection, explicitly requiring service providers to limit the processing of personal information to what is directly related and necessary for service purposes [10]. As illustrated in Figure 1, violations of this principle can increase the risk of data breaches and significantly erode user trust.

Prior research shows that privacy policies commonly contain complex technical terminology [9], making them hard for ordinary users to understand and challenging for experts to conduct large-scale evaluations [6, 29, 40]. Therefore, automatically identifying data minimization violations in privacy policies is essential for protecting user information and reducing regulatory burdens. However, despite rapid advances in natural language processing technologies, several challenges persist when applying them to identify data minimization principle violations. First, the data minimization principle currently lacks specific guidelines tailored to different application scenarios. This ambiguity hinders the establishment of standardized quantitative metrics, forcing evaluations to rely on labor-intensive manual expert reviews. Second, existing tools often struggle to accurately extract fine-grained data practice tuples. Coarse-grained classification leads to broad semantic scopes in extraction results (e.g., “collect email addresses” might be extracted as “collect personal information”), providing unreliable inputs that reduce evaluation accuracy. Third, relying solely on the LLM-as-a-judge method for end-to-end evaluation introduces issues related to model bias and ethical compliance [24, 47]. These challenges limit studies on data minimization evaluation.

Existing approaches fall into two categories. One line of work [42, 49] injects expert knowledge to define a set of necessary data practices for automated evaluation. However, they fail to address the fundamental issue of defining “minimization”, and exhaustive enumeration is impractical due to the rapid evolution of application functionalities. The other line of work [27, 45, 48, 51] follows a counterpart comparison solution to identify necessary data practices. These methods assume that data collected by similar applications is largely necessary, and all collected data serves all described purposes. Specifically, they compute the frequency of each data practice among applications whose descriptions are semantically similar to that of the target application, and regard practices whose

frequencies exceed a predefined threshold as necessary. However, such methods rely on idealized assumptions underlying counterpart comparison, lack comparable reference applications, and focus on the specific action of data collection, which limits their practicality.

To address these issues, we propose **DataMini**¹, a human-LLM collaborative framework for identifying data minimization violations in privacy policies. **First**, we decompose the abstract minimization evaluation into two-dimensional checks: (i) *inherent violation* checks to establish strong correlation standards for specific operations on data for specific purposes; and (ii) *contextual violation* checks to determine if the data and purposes are necessary within the context of the application type. **Second**, we fine-tune the large language model (LLM) using LoRA (Low-Rank Adaptation) and leverage retrieval-augmented generation (RAG) to construct an “extract-combine-verify” pipeline for accurate data practice extraction. **Finally**, using pointwise mutual information (PMI) and co-occurrence probability thresholds, we mine statistical associations to generate candidate mappings. These candidate mappings then undergo a dual review by LLMs and domain experts to produce compliance mappings, which support human-LLM collaborative evaluation. The overall framework shifts expert effort from fully manual review to targeted verification of ambiguous cases, improving efficiency while maintaining accuracy and ethical compliance.

Our main contributions are summarized as follows:

- **Fine-grained Taxonomy of Data Minimization Violations.** To the best of our knowledge, we are the first to evaluate data minimization compliance by integrating data-purpose relevance as a foundational criterion and introducing fine-grained categories that distinguish inherent and contextual violations, thereby providing precise guidance for evaluation.
- **Effective Data Practice Extraction.** We design an “extract-combine-verify” pipeline to achieve effective data practice extraction with an accuracy of 83.46%, serving as the basis for subsequent data minimization evaluation. Specifically, we leverage LoRA fine-tuning to adapt an LLM for extracting data practices from privacy policies accurately, while integrating retrieval-augmented generation to provide supporting evidence for verification.
- **Reliable Compliance Baseline Construction.** By mining high-frequency co-occurrence patterns among data types, actions, purposes, and application types from 12,519 data practices, we derive three types of compliance mappings as the baseline for automated evaluation. This compliance baseline not only reduces manual review efforts but also provides reliable references for violation identification, achieving an accuracy of 82.76%.
- **Efficient Human-LLM Collaborative Framework.** We propose DataMini, an efficient framework that shifts the evaluation process for identifying data minimization violations from labor-intensive manual review to a human-LLM collaborative evaluation paradigm. The framework reduces expert workload by approximately 80% while maintaining accuracy and ethical compliance, representing a significant step towards automated evaluation.

¹The source code of DataMini, the datasets used for evaluation in this paper, and more implementation details are available in our repository <https://github.com/UOHZO/DataMini>.

2 Related Work

2.1 Data Minimization Evaluation

Existing data minimization evaluation research encompasses multiple scenarios, such as model training processes [10, 15, 37], search engines [34], mobile applications [42, 45, 48, 49, 51], and other data-driven scenarios [27]. These studies demonstrate that the definition of *data minimization* exhibits significant task- and context-dependency. In scenarios oriented toward model performance, *data minimization* can be achieved through reducing training data or decreasing feature granularity, with quantitative evaluation conducted by observing whether model performance remains at an acceptable level. However, in broader application scenarios, particularly mobile applications, the lack of quantifiable evaluation metrics makes it challenging to identify which data practices comply with the data minimization principle. Existing methods can be categorized into two types: The first method relies on expert knowledge [42, 49], constructing a finite set of data practices that comply with the data minimization principle based on data protection laws and regulations, and treating any practice outside this set as a violation. Yet, due to the rapid evolution of application functionalities, exhaustively defining necessary data practices remains challenging. The second method [45, 48, 51] makes an idealized assumption: high-frequency data practices among applications providing similar services can be considered necessary and purpose-relevant. This method is constrained by the quantity and quality of retrieved similar application privacy policies; the absence of similar counterparts for some applications can substantially increase false negatives. Recently, researchers have applied LLMs to privacy policy analysis [39, 41, 46]. However, existing studies use LLMs as classifiers to determine whether privacy policies contain legally required disclosures, without conducting evaluations of data minimization. In contrast, we refine the definition of *data minimization*, distinguishing violations into inherent violations and contextual violations to achieve fine-grained evaluation while avoiding broad assumptions. Furthermore, through a human–LLM collaborative review mechanism that combines LLMs with domain experts, DataMini ensures both accuracy and ethical compliance of the results.

2.2 Data Practice Extraction

Data Practice Extraction serves as the foundation for automated privacy policy evaluation. Its objective is to transform unstructured privacy policy text into structured data practice tuples, thereby providing reliable input for subsequent analysis and evaluation. Various automated tools have been developed for data practice extraction: Andow et al. [7] propose PolicyLint, which leverages Hearst patterns [33] to automatically extract data types and operations from privacy policy sentences. Bui et al. [11] introduce PurPliance, utilizing semantic role labeling [19] models to identify data types, actions, and purposes. However, these tools neglect contextual information, hindering comprehensive and accurate data practice extraction from structurally complex privacy policies. Consequently, Cui et al. [13] construct knowledge graphs from extracted data practices to mitigate the limitations of insufficient contextual consideration. However, this approach heavily relies on syntactic patterns during the extraction phase, limiting its generalizability.

Furthermore, existing tools generally employ coarse-grained classifications for actions, data types, and purposes. This generalized processing causes the semantic scope of extracted data practices to exceed the original semantics of privacy policies. To address these limitations, we fine-tune an LLM using LoRA for the extraction task, effectively overcoming the constraints of rule-based or shallow semantic analysis inherent in prior tools. Moreover, we construct fine-grained ontologies for actions, data types, and purposes to ensure semantic alignment between original privacy policies and extracted data practices at the granularity level, while standardizing the formal representation of data practices.

2.3 Retrieval-Augmented Generation

In recent years, the integration of retrieval models and language models has given rise to Retrieval-Augmented Generation technology, which aims to enhance response quality by retrieving external knowledge [14]. A complete standard RAG process first invokes a retriever to search for relevant text in external databases, then feeds these texts along with the original query to a generator to obtain more accurate responses [16]. Since RAG improves generation quality via external knowledge and permits flexible adaptation of the retrieval module without retraining the generator, it has proven effective in various tasks, including fact checking [23, 35] and question answering [18, 36, 43]. Motivated by these advantages, we incorporate RAG into our data practice extraction pipeline. Specifically, we retrieve the most relevant segments from the original privacy policies to verify whether the extracted data practices are explicitly disclosed in the source text, thereby ensuring the accuracy of our extraction.

3 Preliminaries

3.1 Assumptions

Our research problem is built upon the following two assumptions: (i) *Users lack sufficient professional knowledge and patience to read lengthy privacy policies and scrutinize the data practices described therein* [6, 29, 40]. Therefore, relying on users to identify potential violations of the data minimization principle in privacy policies is unrealistic, highlighting the necessity for automated evaluation. (ii) *The majority of applications' privacy policies are not crafted with malicious intent*. Under the constraints of regulations such as the GDPR, application developers typically have incentives to truthfully disclose their data practices to avoid regulatory risks [26]. In this paper, we do not focus on validating the actual implementation of data practices. Instead, we evaluate whether the disclosed practices violate the data minimization principle. Readers interested in the consistency between privacy policies and actual data processing behaviors may refer to [11, 38, 44, 52] for more details.

3.2 Formulation

3.2.1 Privacy Policy and Data Practice. Privacy policies serve as legal documents through which service providers disclose data processing behaviors to users. From the perspective of data minimization evaluation, a privacy policy can be modeled as a collection of structured data practices. Formally, each data practice extracted

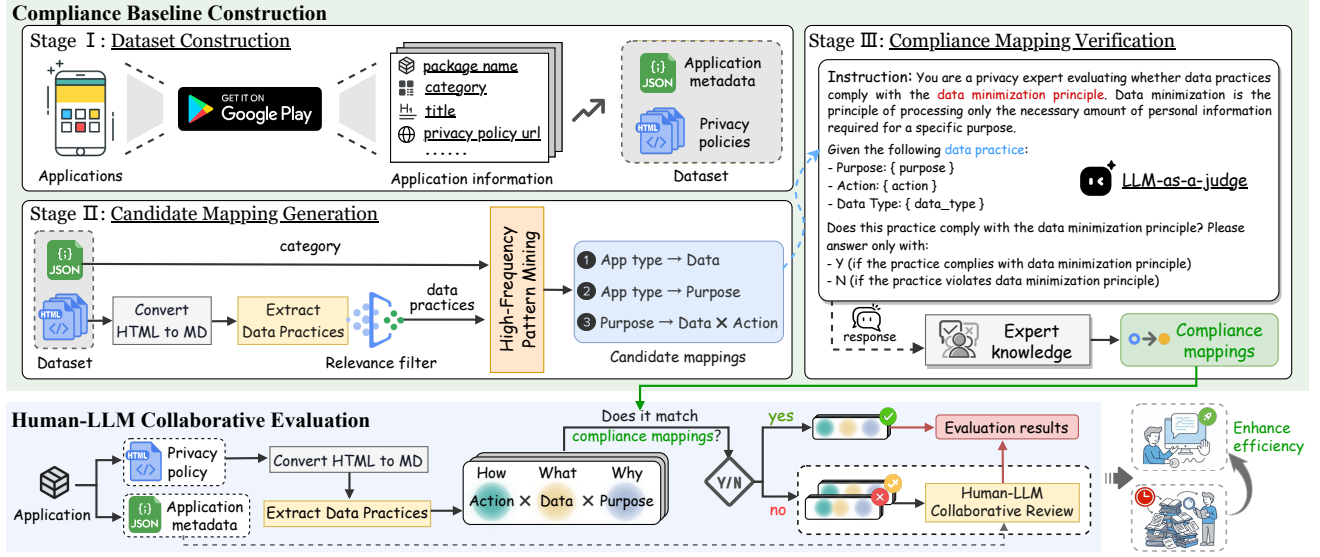


Figure 2: Overview of DataMini. It utilizes compliance mappings generated via high-frequency pattern mining and expert knowledge to support a human–LLM collaborative review, aiming to efficiently and accurately identify data minimization violations in privacy policies.

from a privacy policy is represented as a triple

$$dp = (a, d, p), \quad (1)$$

where $a \in O_A$ denotes the action performed on data, $d \in O_D$ represents the data type being processed, and $p \in O_P$ indicates the purpose for performing the action. For example, “we use your interests for advertising” can be formalized as $(use, interest, advertising)$. Given a privacy policy π , its corresponding data practice set is denoted as

$$DP(\pi) = \{dp_1, dp_2, \dots, dp_n\}. \quad (2)$$

Moreover, each application has corresponding metadata $meta(\pi) = \{category, description, \dots\}$, where *category* represents the application’s classification in app stores², providing essential application context for evaluating the necessity of data practices.

3.2.2 Ontologies. To ensure standardized and consistent representation of data practices, we construct three ontologies: (i) *Action Ontology*. The action ontology O_A is built upon the Data Privacy Vocabulary [21], containing 51 types of actions organized in a hierarchical structure. For instance, both *store* and *use* are subclasses of *process*. (ii) *Data Ontology*. We construct the data ontology O_D by supplementing the Ontology of Personal Information (OPI) [4] with 266 additional terms that are critical for comprehensively describing the data practices found in contemporary applications. While OPI provides a baseline of data types and semantic hierarchical relationships extracted from privacy policies (e.g., *phone_number* is a subclass of *contact_information*), our extension enhances its descriptive capability. (iii) *Purpose Ontology*. The purpose ontology O_P contains 56 data processing purposes, designed based on data protection regulations, covering purposes ranging from functional implementation to commercial marketing.

²We adopt the 48 application categories from Google Play Store’s taxonomy [17]

3.2.3 Data Minimization Principle Violations. We divide data minimization principle violations in privacy policies into two categories: *inherent violations* and *contextual violations*. This categorization is grounded in data-purpose relevance, emphasizing that necessity either stems from data practices themselves or requires consideration of specific application contexts. 1) *Inherent violations* refer to violations that can be identified without additional contextual information. For example, collecting sensitive data unrelated to functionality for “providing basic services” constitutes such a violation. These issues reflect semantic-level unnecessary of data practices, independent of the application’s category. 2) *Contextual violations* refer to violations that can only be determined by considering specific application contexts. For a data practice dp and application metadata $meta(\pi)$, if dp appears unnecessary within the context of $meta(\pi)$, despite potentially being legitimate in other application types, it constitutes a contextual violation. For instance, $(collect, financial\ records, functionality)$ is necessary in financial applications but may constitute a violation in other applications.

3.2.4 Problem Definition. Based on the above definitions, our research problem can be defined as follows: Given a privacy policy π and corresponding application metadata $meta(\pi)$, our goal is to derive the set of extracted data practices $DP(\pi)$ and identify the subset $\mathcal{V} \subseteq DP(\pi)$ of practices that violate the data minimization principle. Specifically, $\mathcal{V} = \mathcal{V}_{inh} \cup \mathcal{V}_{ctx}$, where $\mathcal{V}_{inh}$ and $\mathcal{V}_{ctx}$ represent the sets of practices identified as *inherent violations* and *contextual violations*, respectively.

4 Design of DataMini

In this section, we present DataMini, a human–LLM collaborative evaluation framework for effectively reducing the workload

of manual review, marking an important step toward automatically identifying violations of the data minimization principle in privacy policies. As shown in Figure 2, the framework consists of two main components: **compliance baseline construction** and **human-LLM collaborative evaluation**. The compliance baseline construction component processes large-scale privacy policies to extract high-frequency co-occurrence patterns among actions, data types, and purposes, as well as frequent data types and purposes associated with specific application categories. Based on these patterns, a dual-review process involving both LLMs and domain experts is conducted to derive mappings that genuinely satisfy the data minimization principle from these high-frequency patterns, forming a set of scalable and reusable compliance mappings. The resulting compliance mappings serve as reusable expert knowledge to identify data practices that comply with the data minimization principle and filter them out of the pending evaluation set, thereby minimizing redundant reviews. During the human-LLM collaborative evaluation phase, only those data practices that do not fully match the compliance mappings (marked as suspected violations) undergo further review by LLMs and experts to obtain the final evaluation results, determining which data practices in a given privacy policy violate the data minimization principle.

4.1 Compliance Baseline Construction

To enhance automated evaluation capabilities, we design a three-stage method for constructing a data minimization compliance baseline. First, we build a large-scale dataset based on Google Play, containing privacy policies and their corresponding application metadata (including application categories and descriptions). We then automatically extract data practices from this dataset with high accuracy and apply association analysis to mine high-frequency patterns among them, thereby generating candidate mappings. Finally, the LLM takes the candidate mappings as input and combines expert knowledge to verify its output, producing the compliance mappings that serve as the subsequent evaluation baseline.

4.1.1 Dataset Construction. To mine high-frequency co-occurrence patterns among actions, data types, and purposes in data practices, as well as high-frequency data types and purposes associated with specific application categories, it is essential to construct a large-scale and representative privacy policy dataset that covers diverse application categories. Therefore, we initiate our dataset construction with 36,167 Google Play application package names extracted from 202 million Android smartphone usage logs³ spanning over 14,000 users, which capture real-world user behavior and support subsequent data minimization evaluation. Based on these collected package names, we then utilize the *google-play-scraper* library [22] to retrieve corresponding application metadata, including application category, title, and privacy policy URLs. For each privacy policy URL, we retrieve the corresponding webpage using the *requests* library [32] and store it as an HTML file. Regarding data quality control, we implement a rigorous filter to exclude samples with invalid package names, unreachable privacy policy links, or non-English privacy policies. Finally, we construct a dataset, denoted as

$\mathcal{D}_{app}$, consisting of 12,519 high-quality privacy policies along with their corresponding metadata information.

4.1.2 Candidate Mapping Generation. We first leverage the *trafilatura* library [8] to eliminate interfering elements such as navigation components, advertisement banners, and script codes from HTML files, while preserving core textual content and its original heading hierarchy. This process converts HTML files into Markdown-formatted privacy policy documents for subsequent structural processing and analysis. We then employ an “extract–combine–verify” pipeline that combines the semantic understanding capabilities of LLMs with RAG techniques to convert each privacy policy in $\mathcal{D}_{app}$ into a set of semantically equivalent data practices, as shown in Figure 3. Finally, based on PMI and co-occurrence probability thresholds, we conduct statistical association mining to transform the extracted data practices into three types of candidate mappings: $purpose \rightarrow action \times data$, $app\ type \rightarrow purpose$, and $app\ type \rightarrow data$.

Data Practice Extraction. In the *extraction phase*, we fine-tune a base LLM using LoRA to construct our extraction model $\mathcal{M}_{ext}$. While the use of LoRA ensures efficient training and deployment, adopting a paragraph-level approach enables the model to leverage context more effectively. The detailed training procedures and model effectiveness are discussed in Section 5.1.

Let a privacy policy π be a sequence of paragraphs $\{x_1, x_2, \dots, x_n\}$. For each privacy policy paragraph x_i , the model extracts a set of raw elements containing actions, data types, and purposes:

$$A_{raw}^{(i)}, D_{raw}^{(i)}, P_{raw}^{(i)} = \mathcal{M}_{ext}([\text{INST}]_a, [\text{INST}]_d, [\text{INST}]_p, x_i) \quad (3)$$

where $[\text{INST}]_a$, $[\text{INST}]_d$, and $[\text{INST}]_p$ are the extraction instructions for actions, data types, and purposes, respectively. We then aggregate the results across all paragraphs to obtain the raw set $A_{raw} = \bigcup_i A_{raw}^{(i)}$, and similarly for D_{raw} and P_{raw} , serving as the basis for the semantic normalization performed in the subsequent *combination phase*.

In the *combination phase*, we align the extracted raw sets with pre-constructed ontologies (i.e., $\mathcal{O}_A, \mathcal{O}_D, \mathcal{O}_P$). Raw extractions often suffer from linguistic variability, where semantically equivalent concepts are expressed using diverse vocabularies (e.g., “surname” and “last name”), resulting in terminological heterogeneity. Such heterogeneity poses significant challenges for the subsequent statistical analysis of data practices. Therefore, we define a mapping function $f_{map}(e, \mathcal{O})$ that maps a raw element e to a term $n \in \mathcal{O}$ based on semantic similarity:

$$f_{map}(e, \mathcal{O}) = \underset{n \in \mathcal{O}}{\operatorname{argmax}} \operatorname{sim}(\mathbf{v}_e, \mathbf{v}_n), \quad \text{s.t. } \operatorname{sim}(\mathbf{v}_e, \mathbf{v}_n) > \delta, \quad (4)$$

where $\mathbf{v}$ denotes the embedding vector and δ is a predefined threshold (0.7). Consequently, we obtain the normalized action set $\hat{A}$ by applying this mapping to the raw action set A_{raw} :

$$\hat{A} = \{f_{map}(a, \mathcal{O}_A) \mid a \in A_{raw}\}. \quad (5)$$

The normalized sets for data types ($\hat{D}$) and purposes ($\hat{P}$) are derived in an analogous manner using $\mathcal{O}_D$ and $\mathcal{O}_P$, respectively. Subsequently, we construct the candidate pair set C_{cand} by computing the Cartesian product of the normalized action and data type sets:

$$C_{cand} = \hat{A} \times \hat{D} = \{(a, d) \mid a \in \hat{A}, d \in \hat{D}\}. \quad (6)$$

³<https://www.kaggle.com/datasets/kbogh/android-apps-metadata/data>

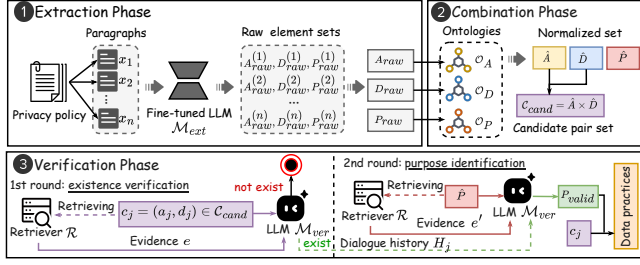


Figure 3: The “extract–combine–verify” pipeline.

These candidate pairs, together with the corresponding normalized purpose set $\hat{P}$, serve as inputs for the *verification phase*, where the specific purpose(s) associated with each pair are inferred.

In the *verification phase*, we employ a retrieval-augmented two-round dialogue, where a retriever $\mathcal{R}$ extracts relevant evidence to augment the prompts for a generic LLM, denoted as $\mathcal{M}_{ver}$. This design is driven by two considerations: First, the retrieval-augmented approach is designed to circumvent the limitations of processing entire privacy policies. Dealing with long contexts introduces issues such as long-context dependency[25], context forgetting[28], and increased hallucination risks[20], all of which impair the LLM’s comprehension and response quality[31]. Incorporating RAG mitigates these issues while ensuring that each model’s judgment is grounded in specific evidence from the policy. Second, the two-round dialogue aims to resolve the combinatorial explosion issue. Decomposing into two rounds enhances efficiency, allows the model to preserve contextual information via dialogue history while maintaining focused attention on the specific sub-task of each round.

To facilitate precise retrieval, we use the BGE-M3 model [12] as the retriever, leveraging its hybrid retrieval mechanism that combines dense vectors (capturing global semantic similarity) and ColBERT vectors (capturing token-level similarity). Furthermore, we implement a *structure-aware chunking strategy* aligned with the organizational hierarchy (e.g., headers and sections) of privacy policies to ensure each chunk constitutes a semantically complete unit. For sections exceeding token limits, we apply secondary subdivision prioritized by paragraph boundaries. The resulting chunks (i.e., evidences) are vectorized and stored in a vector database.

Specifically, for each candidate pair $c_j = (a_j, d_j) \in C_{cand}$, the dialogue proceeds in two rounds: the first round performs *existence verification*, and the second conducts *purpose identification*. For existence verification, we first retrieve the most relevant evidence e from the vector database, and then instruct the model to determine the existence of the candidate pair based on the evidence e :

$$e = \mathcal{R}(c_j, \pi), \quad (7)$$

$$y_{exist} = \mathcal{M}_{ver}([\text{INST}]_{ver_pair}, e, c_j), \quad (8)$$

where $y_{exist} \in \{Y, N\}$. If $y_{exist} = N$, indicating the pair c_j is invalid, the verification process terminates. Conversely, if $y_{exist} = Y$, we proceed to the next dialogue round. For purpose identification, we retrieve evidence e' relevant to the candidate purpose set $\hat{P}$ and prompt the model incorporating the dialogue history H_j (which contains the context from the last round):

$$e' = \mathcal{R}(\hat{P}, \pi), \quad (9)$$

$$P_{valid} = \mathcal{M}_{ver}([\text{INST}]_{ver_purp}, e', \hat{P}, H_j). \quad (10)$$

The model then identifies the subset of actual purposes $P_{valid} \subseteq \hat{P}$ that matches the pair c_j . Finally, the complete data practice triples are constructed as $\{(a_j, d_j, p) \mid p \in P_{valid}\}$.

High-Frequency Pattern Mining. We extract three types of candidate mappings from the large-scale privacy policy dataset $\mathcal{D}_{app}$ via statistical association mining to identify high-quality mappings that potentially adhere to the data minimization principle, thereby facilitating the generation of compliance mappings. Let $\mathcal{T}$ denote the set of application categories. The candidate mappings are formalized as follows: (i) *purpose* $\rightarrow$ *action* $\times$ *data mappings*, identifying high-frequency data processing patterns under specific purposes; (ii) *app type* $\rightarrow$ *purpose mappings*, capturing purpose distributions across categories; and (iii) *app type* $\rightarrow$ *data mappings*, revealing data type preferences of various application categories.

Given the hierarchical structure of our ontology where upper-level terms represent abstract concepts and lower-level terms represent specific instances, we employ a propagation strategy when computing co-occurrence statistics. Let $\mathcal{O}$ represent the ontology tree and $Desc(n)$ be the set of descendant terms for a node $n \in \mathcal{O}$. We define an expansion function $\Psi(n) = \{n\} \cup Desc(n)$. Specifically, given a data practice triple $dp = (a, d, p)$, we update the co-occurrence counts not just for dp , but for all elements in the Cartesian product of their expanded sets. For instance, when *(collect, contact information, advertising)* appears, since *phone number* $\in \Psi(\text{contact information})$, we increment the count for *(collect, phone number, advertising)*. This approach preserves fine-grained specific practices while capturing coarse-grained abstract patterns.

The mining process employs a two-stage filtering strategy to derive the candidate mapping set $\mathcal{MAP}^*$. First, we use PMI to measure the correlation. For data d and purpose p , the correlation is defined as

$$PMI(d, p) = \log \frac{P(d, p)}{P(d)P(p)}, \quad (11)$$

where $P(d, p)$ denotes the co-occurrence probability, and $P(d), P(p)$ denote the marginal probabilities of d and p , respectively. We define the data practices passing the relevance filter as $DP_{rel} = \{(a, d, p) \mid PMI(d, p) > \alpha\}$.

Second, we retain only mappings with co-occurrence probability exceeding predefined thresholds. This step filters incidental associations and ensures statistical significance of candidate mappings. The candidate mapping set $\mathcal{MAP}^*$ is formalized as:

$$\begin{aligned} \mathcal{MAP}_{pad}^* &= \{(a, d, p) \mid (a, d, p) \in DP_{rel}, P(a, d, p) > \beta\}, \\ \mathcal{MAP}_{tp}^* &= \{(t, p) \mid (a, d, p) \in DP_{rel}, t \in \mathcal{T}, P(t, p) > \gamma\}, \\ \mathcal{MAP}_{td}^* &= \{(t, d) \mid (a, d, p) \in DP_{rel}, t \in \mathcal{T}, P(t, d) > \sigma\}, \\ \mathcal{MAP}^* &= \mathcal{MAP}_{pad}^* \cup \mathcal{MAP}_{tp}^* \cup \mathcal{MAP}_{td}^*. \end{aligned} \quad (12)$$

The determination of these threshold parameters $(\alpha, \beta, \gamma, \sigma)$ is detailed in Section 5.2.

4.1.3 Compliance Mapping Verification. To support subsequent human–LLM collaborative evaluations, we identify mappings that comply with the data minimization principle from the candidate mappings $\mathcal{MAP}^*$, yielding the compliant mappings $\mathcal{MAP}$. This set of compliant mappings is scalable and reusable, enabling efficient detection of obviously compliant data practices and reducing

human effort. In this stage, we design a collaborative evaluation method that integrates LLM evaluation with expert knowledge to balance efficiency and reliability. While the “LLM-as-a-Judge” evaluation improves efficiency, inherent model biases[31] and regulatory mandates for human oversight[5] necessitate this collaborative paradigm to ensure fairness and accuracy.

Specifically, we use an ensemble model $\mathcal{M} = \{M_1, M_2, M_3\}$ comprising three distinct LLMs to improve evaluation accuracy. We utilize carefully designed instruction templates $[\text{INST}]_{\text{eval}}$ to guide each model $M_k \in \mathcal{M}$ in evaluating whether a candidate mapping $map \in \mathcal{MAP}^*$ adheres to the data minimization principle. For each mapping map , the model outputs a binary judgment $v_k \in \{Y, N\}$ (where Y represents “Compliant”) and a rationale r_k :

$$(v_k, r_k) = M_k([\text{INST}]_{\text{eval}}, map). \quad (13)$$

To enhance reliability, the preliminary consensus and confidence score are determined through majority voting and averaging. For instance, if two models output “Y”, the confidence score is 2/3. Subsequently, all model outputs (“Y” or “N”), corresponding rationales, and confidence scores are submitted to domain experts for review. Finally, experts give the definitive judgments based on LLM evaluations to determine whether the candidate mapping should be included in the compliance mappings.

4.2 Human-LLM Collaborative Evaluation

Given a mobile application, we leverage the compliance baseline constructed above to identify the data practices in the corresponding privacy policy π that violate the principle of data minimization, producing the final evaluation results. The overall human-LLM collaborative evaluation consists of the following three steps.

Preprocessing. Given an application, its privacy policy π and metadata $meta(\pi)$ are obtained, incorporating the application category and description as contextual input for the LLM. The HTML-based policy is converted into structured Markdown, followed by the extraction of data practice triples $DP(\pi)$ using the data practice extraction pipeline.

Compliance Mapping Matching. We match each extracted data practice triple $dp = (a, d, p) \in DP(\pi)$ against the compliance mappings $\mathcal{MAP} = \mathcal{MAP}_{pad} \cup \mathcal{MAP}_{tp} \cup \mathcal{MAP}_{td}$ (Section 4.1). Specifically, for $purpose \rightarrow action \times data$ mappings, we check whether $p \rightarrow a \times d$ exists in the compliance mappings; absence indicates a suspected inherent violation, suggesting the action-data combination may be unnecessary for the stated purpose. Similarly, for $app\ type \rightarrow purpose$ and $app\ type \rightarrow data$ mappings, we examine whether $meta(\pi).category \rightarrow p$ and $meta(\pi).category \rightarrow d$ exist in compliance mappings; absence indicates suspected contextual violations, suggesting the purpose/data may be reasonable for other application categories but inappropriate in the current context.

Reviewing. To ensure accuracy, suspected violations undergo the human-LLM collaborative review: the application metadata $meta(\pi)$, the suspected violation dp , and the privacy policy π are provided to the LLM. The model determines whether it is a true violation, classifies the violation type (inherent or contextual), and provides a rationale. Finally, domain experts review the model outputs to render the definitive judgment for the final evaluation.

The evaluation paradigm offers three key advantages: (i) Enhanced efficiency through pre-screening using compliance mappings, substantially reducing expert review requirements; (ii) Fine-grained analysis via inherent and contextual violation distinction, enabling targeted privacy policy improvements; (iii) Scalability through continuous expansion of compliance mappings, maintaining applicability across evolving app ecosystems and regulatory requirements.

5 Experimental Results

In this section, we conduct a comprehensive empirical evaluation to examine whether DataMini can reliably support automated identification of data minimization violations in privacy policies. Specifically, we evaluate the effectiveness of data practice extraction, determine optimal threshold parameters for constructing the compliance baseline, and assess the performance of DataMini in identifying violations of the data minimization principle in privacy policies. To facilitate reproducibility, we have made examples of all datasets used in our experiments available in our anonymous repository.

5.1 Effectiveness of Data Practice Extraction

We evaluate the performance of our fine-tuned models in extracting actions, data types, and purposes from privacy policies, as the accurate identification of these elements is a prerequisite for obtaining complete data practices. Subsequently, we assess whether the data practice extraction pipeline can generate reliable and structured inputs for subsequent violation identification.

5.1.1 Datasets. We construct two datasets: (i) Fine-tuning dataset: We sample 2,250 paragraphs from 50 privacy policies in $\mathcal{D}_{app}$, split into training and test sets (in a 2:1 ratio) for action, data type, and purpose extraction tasks. (ii) Evaluation dataset: To rigorously evaluate generalization on unseen data, we select 50 distinct privacy policies from $\mathcal{D}_{app}$ that do not overlap with the fine-tuning dataset. This evaluation dataset $\mathcal{G}_{dp}$ contains 409 manually annotated ground truth data practice triples. All labels are independently annotated by three graduate students with privacy research backgrounds. Prior to formal annotation, annotators receive training on the definitions of actions, data types, and purposes in the context of privacy policies. Each paragraph is then labeled independently by all three annotators. Disagreements are resolved through majority voting, and cases requiring further deliberation are discussed collectively until consensus is reached. Throughout the annotation process, we conduct periodic reviews to ensure consistency and quality.

5.1.2 Baselines. We fine-tune six widely used open-source LLMs (Qwen2.5-7B, Qwen2.5-14B, Gemma-3-12B, Baichuan2-7B, Llama-3.1-8B, Baichuan2-13B), and compare these fine-tuned models with both their corresponding base models and representative privacy analysis tools (Purpliance [11], PolicyLint [7], PoliGraph [13]). We then compare the extracted data practices against the dataset $\mathcal{G}_{dp}$ to demonstrate the effectiveness of our extraction pipeline.

5.1.3 Evaluation Metrics. For *element extraction*, we evaluate data practice element extraction using both exact matching and semantic similarity-based soft matching metrics: (i) *Exact match*. Given a reference set R and a predicted set Q , precision (P_{EX}), recall (R_{EX}),

Table 1: Comparative evaluation of element extraction performance across different LLMs and existing tools. The table reports the ROUGE-L (F_{LCS}) and exact-match (F_{EX}) scores for both the base and fine-tuned (denoted by *) models, as well as for existing tools (denoted by †). The results demonstrate the positive impact of fine-tuning on extraction accuracy, with fine-tuned models outperforming base models and existing tools.

Model/Method	Overall		Data Extraction		Action Extraction		Purpose Extraction	
	F_{LCS}	F_{EX}	F_{LCS}	F_{EX}	F_{LCS}	F_{EX}	F_{LCS}	F_{EX}
Gemma-3-12B*	0.8579	▲0.2524	0.8353	▲0.2649	0.8254	▲0.1735	0.7999	▲0.1841
Gemma-3-12B	0.6055		0.5704		0.6519		0.6158	
Qwen2.5-14B*	0.8550		0.8317		0.8639	▲0.2520	0.8319	▲0.1696
Qwen2.5-14B	0.6717	▲0.1833	0.6406	▲0.1911	0.6186	▲0.2453	0.5809	▲0.1619
Llama-3.1-8B*	0.8481		0.8270		0.8390	▲0.5510	0.8450	▲0.5643
Llama-3.1-8B	0.3126	▲0.5355	0.2625	▲0.5645	0.3139	▲0.2604	0.2807	▲0.5833
Baichuan2-7B*	0.8460		0.8272		0.8355	▲0.4442	0.8396	▲0.4902
Baichuan2-7B	0.4382	▲0.4078	0.4162	▲0.4110	0.3844	▲0.4511	0.3494	▲0.5020
Qwen2.5-7B*	0.8434		0.8198		0.8070	▲0.2447	0.8352	▲0.1889
Qwen2.5-7B	0.6730	▲0.1704	0.6575	▲0.1623	0.5623	▲0.2558	0.6463	▲0.1876
Baichuan2-13B*	0.8424		0.8179		0.8135	▲0.5545	0.8551	▲0.5675
Baichuan2-13B	0.2744	▲0.5680	0.2369	▲0.5810	0.2663	▲0.5472	0.2248	▲0.5545
PoliGraph†	0.5894		0.5263		0.4555	0.3190	0.5280	0.5280
Purpliance†	0.6799		0.6414		0.6140	0.5423	0.6431	0.6579
PolicyLint†	0.6176		0.5936		0.5775	0.5227	0.6577	0.6644

and F1 score (F_{EX}) are defined as:

$$P_{EX} = \frac{|R \cap Q|}{|Q|}, R_{EX} = \frac{|R \cap Q|}{|R|}, F_{EX} = \frac{2 \cdot P_{EX} \cdot R_{EX}}{P_{EX} + R_{EX}}. \quad (14)$$

(ii) *ROUGE-L score*. Given a reference sequence $X = \{x_1, \dots, x_m\}$ and a predicted sequence $Y = \{y_1, \dots, y_n\}$, recall (R_{LCS}), precision (P_{LCS}), and F1 score (F_{LCS}) are computed as:

$$R_{LCS} = \frac{LCS(X, Y)}{|X|}, P_{LCS} = \frac{LCS(X, Y)}{|Y|}, F_{LCS} = \frac{2 \cdot P_{LCS} \cdot R_{LCS}}{P_{LCS} + R_{LCS}}. \quad (15)$$

For *data practice extraction*, considering inherent granularity differences between LLM outputs (often more detailed) and manual annotations (often more abstract), we employ an embedding-based similarity metric to avoid penalizing semantically equivalent but differently expressed predictions. Given a reference triple $t_r = (a_r, d_r, p_r)$ and predicted triple $t_p = (a_p, d_p, p_p)$, their similarity is defined as:

$$s(t_r, t_p) = \frac{1}{3} [\text{sim}(a_r, a_p) + \text{sim}(d_r, d_p) + \text{sim}(p_r, p_p)], \quad (16)$$

where $\text{sim}(\cdot)$ denotes cosine similarity between embeddings generated by the all-MiniLM-L6-v2 model. Based on this definition, we design two metrics: (i) *Coverage*, $Cov = \frac{1}{|R|} \sum_{t_r \in R} \max_{t_p \in Q} s(t_r, t_p)$, measuring the average extent to which reference triples are covered by predictions; (ii) *Accuracy*, $Acc = \frac{1}{|Q|} \sum_{t_p \in Q} \max_{t_r \in R} s(t_r, t_p)$, measuring the semantic accuracy of predicted triples. Here, R and Q denote the reference and predicted data practice sets, respectively.

5.1.4 Implementation and Results. We implement instruction fine-tuning using LLaMA Factory [50] with LoRA (rank=8, scaling factor=16, dropout=0.05) on a single NVIDIA A100-SXM4 40GB GPU. As shown in Table 1, targeted fine-tuning achieves significant improvements across all extraction tasks: compared to base models, fine-tuned models achieve average ROUGE-L F_{LCS} gains of 0.17–0.57 and exact matching F_{EX} gains of 0.17–0.58. These gains primarily stem from more focused, format-compliant outputs that reduce redundant text commonly produced by base models. More

importantly, fine-tuned LLMs significantly outperform existing privacy analysis tools, including Purpliance, PolicyLint, and PoliGraph, across all evaluation dimensions. While PoliGraph and PolicyLint achieve moderate performance in certain categories, their overall ROUGE-L and exact-match scores remain substantially below those of fine-tuned LLMs. Purpliance performs comparatively better among the tools but still lags behind fine-tuned models by a considerable margin.

Among all evaluated models, the fine-tuned Gemma-3-12B model achieves the best overall performance, with the highest scores across most metrics. Consequently, we select this model as the backbone of our data practice extraction pipeline. On the unseen evaluation dataset $\mathcal{G}_{dp}$, DataMini achieves a coverage of 80.70% and an accuracy of 83.46%, demonstrating its effectiveness for structured data practice extraction. Finally, we apply DataMini to the full dataset $\mathcal{D}_{app}$, extracting 875,499 data practice triples from 12,519 privacy policies.

5.2 Reliability of Compliance Baseline

To establish a reliable compliance baseline, we analyze how different co-occurrence probability thresholds affect the proportion of high-quality mappings complying with data minimization, determine the optimal threshold, and generate the compliance mappings.

5.2.1 Dataset. For each co-occurrence probability threshold in $[0, 1]$ with a step size of 0.01, we first apply the threshold to filter candidate mappings. We then randomly sample 500 mappings from each of the three mapping types among the retained results, and manually annotate them to construct $\mathcal{G}_{map}$, which is used to evaluate the reasonableness of different threshold settings. If fewer than 500 mappings remain under a given threshold, we skip that threshold because the resulting sample size is insufficient for reliable statistical analysis. Three annotators with privacy research and data protection backgrounds independently label each sampled mapping. Due to the lack of explicit legal standards for data minimization violations, annotators primarily rely on their domain knowledge

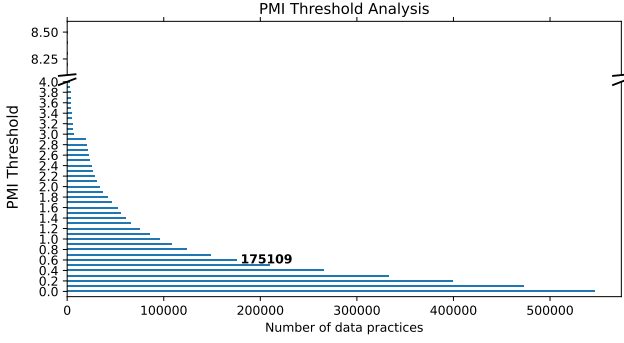


Figure 4: The number of preserved data practice triples under different PMI thresholds.

to assess whether each mapping represents a reasonable data practice. A senior expert in data security and privacy compliance then reviews all annotations to ensure consistency, with disagreements resolved through collective discussion until consensus is reached.

5.2.2 Evaluation Metrics. The goal of candidate mapping generation is to identify mappings that potentially comply with the data minimization principle for subsequent expert verification. Accordingly, our evaluation considers both (i) the filtering effectiveness of different thresholds and (ii) the number of candidate mappings retained at each threshold. We quantify the filtering capability using the violation rate $R_{vio}(t)$, defined as the proportion of non-compliant mappings among the candidate set. Formally, $R_{vio}(t) = \frac{|M_{vio}(t)|}{|M_{total}(t)|}$, where $M_{total}(t)$ denotes the set of mappings with a co-occurrence probability $p > t$, and $M_{vio}(t)$ denotes the subset of $M_{total}(t)$ that violates the data minimization principle.

5.2.3 Implementation Details and Results. We first remove data practices that contain semantically irrelevant data-purpose pairs using PMI. Negative PMI values indicate a negative association between data type d and purpose p ; PMI values of zero signify statistical independence; and larger positive values denote stronger associations. To determine the PMI threshold α , we conduct a sensitivity analysis by varying it from 0 to its maximum value of 8.44 in increments of 0.2, and examine the number of retained data practice triples at each point (Figure 4). To balance the removal of irrelevant data-purpose pairs with coverage of relevant ones, we set the PMI threshold α to 0.6, which can filter out weak associations while maintaining sample diversity.

On the retained set of data practice triples, we further conduct a sensitivity analysis over co-occurrence probability thresholds to evaluate their impact on both violation rate and candidate set size. This analysis can be viewed as a grid search over threshold values. For *purpose* $\rightarrow$ *action* $\times$ *data mappings*, when the threshold is 0 (retaining all mappings), the violation rate reaches a maximum of 79%. As the threshold increases, the violation rate drops rapidly and stabilizes between 60%–69% once the threshold exceeds 0.02. Meanwhile, the number of candidate mappings decreases significantly from 465,142 at threshold 0 to 22,150 at 0.01 and 11,108 at 0.02. Beyond this point, further increasing the threshold yields only marginal improvements in violation rate while continuously reducing

the candidate set size. Therefore, we set the probability threshold β for *purpose* $\rightarrow$ *action* $\times$ *data mappings* to 0.02, balancing filtering quality and manual verification cost. Similarly, we set corresponding thresholds for *app type* $\rightarrow$ *purpose mappings* (γ) and *app type* $\rightarrow$ *data mappings* (σ) to 0 and 0.01, respectively (for *app type* $\rightarrow$ *purpose mappings*, since the number of mappings is already small at threshold 0, no further threshold filtering is applied). In computing violation rates, we observe instances of high co-occurrence that constitute violations. Our analysis attributes this primarily to ambiguous language in privacy policies. For example, many privacy policies claim to collect personal information for service improvement, making the overly broad data type “personal information” strongly associated with the “service improvement” purpose, but this data practice itself violates the data minimization principle.

Finally, with the threshold settings fixed ($\alpha = 0.6$, $\beta = 0.02$, $\gamma = 0$, $\sigma = 0.01$), we obtain 5,130 compliance mappings from the original 16,696 candidate mappings, resulting in an overall retention rate of 30.7%. Specifically, this set comprises 3,670 (of 11,108) *purpose* $\rightarrow$ *action* $\times$ *data mappings*, 692 (of 1,836) *app type* $\rightarrow$ *purpose mappings*, and 768 (of 3,752) *app type* $\rightarrow$ *data mappings*. These compliance mappings provide sufficient diversity and coverage to support the assessment of data minimization principle violations in mobile application privacy policies. Although data processing patterns in some emerging application categories may not be fully captured in current statistics, the compliance mappings are extensible: they can be continuously mined using the method in Section 4.1.2, or incrementally expanded during evaluation with DataMini. Therefore, we leave the construction of a more comprehensive set of compliance mappings to future work.

5.3 Performance of Violation Identification

We evaluate the overall performance of DataMini in identifying data practices that violate the data minimization principle in privacy policies. Specifically, given a target application’s privacy policy and associated metadata, our goal is to accurately identify all violations in the privacy policy.

5.3.1 Dataset. To construct the evaluation dataset $\mathcal{G}_{e2e}$, we randomly sample privacy policies from 50 applications in $\mathcal{D}_{app}$. During annotation, three annotators are provided with complete application metadata (including application categories and descriptions) along with the original privacy policy as reference context. For each data practice triple extracted from the policy, annotators determine whether it violates the data minimization principle or complies with it. For triples labeled as violations, annotators further classify the violation type as either inherent or contextual. We resolve disagreements via majority voting, and a domain expert performs a final review of all labels to ensure quality and consistency. The resulting $\mathcal{G}_{e2e}$ dataset contains 915 labeled data practice samples, including 654 violations and 261 compliant instances.

5.3.2 Evaluation Metrics. We employ the F1-score to evaluate the identification capability of DataMini, defined as follows:

$$\text{Pre} = \frac{TP}{TP + FP}, \quad \text{Rec} = \frac{TP}{TP + FN}, \quad \text{F1} = \frac{2 \cdot \text{Pre} \cdot \text{Rec}}{\text{Pre} + \text{Rec}}, \quad (17)$$

where TP is the number of data practices correctly identified as violations of the data minimization principle, FP denotes the number

of compliant practices incorrectly identified as violations, and FN is the number of violations that are not identified.

5.3.3 Implementation Details and Results. We apply DataMini to $\mathcal{G}_{e2e}$ to evaluate its effectiveness as a human–LLM collaborative framework for identifying data practices that violate the data minimization principle. First, we extract structured data practices from privacy policies using our data practice extraction pipeline. These extracted data practices are then automatically matched against pre-constructed compliance mappings: 12.68% (116/915) of the practices fully match across all three mapping types and are therefore classified as compliant with the data minimization principle. Beyond serving as reusable expert knowledge for identifying compliant data practices, the compliance mappings demonstrate remarkable effectiveness in detecting and categorizing violations. To validate this capability, we compare the preliminary violation labels produced by the compliance mappings (including both inherent and contextual violations) with the expert-reviewed ground truth in $\mathcal{G}_{e2e}$. This comparison yields an accuracy of 82.76% (528/638). This result demonstrates that the compliance baseline can reliably support early-stage violation screening and categorization.

The remaining 799 data practices that satisfy only one or two of the three mapping types (i.e., partial matches) are flagged as suspected violations and forwarded to an LLM for further review. Here, we use the GPT-5 model (accessed in January 2026) with API parameters set to default values (temperature = 1.0, top-p = 1.0). Among these suspected cases, the LLM identifies 494 as violations of the data minimization principle, including 294 inherent violations and 200 contextual violations. Compared with the ground truth in $\mathcal{G}_{e2e}$, DataMini achieves an F1-score of 0.8180, with a precision of 0.9717 and recall of 0.7063. The high precision indicates that DataMini effectively avoids false positives, which is essential in practice because excessive false alarms would substantially increase the burden of compliance audits. However, due to the complexity and subjectivity inherent in data minimization evaluation, our method still leaves room for improvement in terms of recall. To this end, we plan to explore several promising strategies in future work, such as incorporating Chain-of-Thought prompting to guide the LLM through more explicit reasoning steps and establishing feedback mechanisms whereby expert corrections progressively refine the compliance baseline, thereby further enhancing the utility of the framework.

More importantly, the observed discrepancies between the LLM’s judgments and expert labels suggest that even models with strong natural language understanding can deviate from expert assessments, particularly when nuanced analysis that integrates specific application scenarios and legal provisions is required. This finding further supports our decision to adopt a human-in-the-loop approach rather than relying solely on LLM-based evaluation.

In addition to accuracy, DataMini substantially reduces expert workload by shifting the task from manual discovery and in-depth analysis to streamlined verification and validation. To quantify this efficiency gain, we define the information reduction rate as $R = 1 - (L_{mini}/L_{full})$, where L_{full} represents the total length of the original privacy policy and L_{mini} denotes the length of the concise explanations provided by DataMini. Our results show a reduction of approximately 80%. This significant decrease in reading volume

alleviates the burden of manual assessment, enabling experts to focus their attention on judging complex, borderline cases.

6 Conclusion

In this work, we propose DataMini, a human–LLM collaborative framework for identifying violations of the data minimization principle in privacy policies. Through extensive experiments on a large-scale dataset comprising privacy policies from 12,519 mobile applications, we show that DataMini can accurately extract structured data practices from privacy policies, construct reliable compliance baselines, and effectively identify both inherent and contextual violations of data minimization. Moreover, DataMini reduces the burden of manual expert evaluation by approximately 80% by providing concise rationales for decisions rather than requiring the review of full policy texts. This shifts compliance analysis from exhaustive manual review to efficient verification, enabling experts to focus on complex and borderline cases. However, analysis of misidentified cases reveals that fully automated end-to-end detection of data minimization violations remains challenging. On the one hand, data minimization assessment is highly context-dependent, as the same data collection practice may yield different compliance judgments depending on the application scenario and purpose, necessitating expert review for complex and ambiguous cases. On the other hand, data minimization inherently involves balancing privacy against utility. Some data processing may be technically “relevant” but ethically “excessive”, yet current LLMs lack the nuanced ethical reasoning and understanding of societal values that humans bring to such determinations. Therefore, these findings further highlight the soundness and practical value of our proposed human–LLM collaborative evaluation framework, where experts are instructed to critically evaluate the LLM-generated outputs rather than simply accept them. In future work, we will explore enhancing LLMs’ contextual understanding of privacy policies to better approximate expert-level reasoning, thereby further improving the automation capabilities of DataMini.

Acknowledgments

This work was supported by the National Key Research and Development Program of China (2023YFB3106505) and the National Natural Science Foundation of China (U24A20240).

References

- [1] 2018. General Data Protection Regulation (GDPR). <https://gdpr-info.eu/>
- [2] 2020. The California Privacy Rights Act of 2020 (CPRA). <https://theprpa.org/>
- [3] 2021. Personal Information Protection Law of the People’s Republic of China (PIPL). <https://personalinformationprotectionlaw.com/>
- [4] 2023. Ontology of Personal Information. <https://opi.cs.cmu.edu/>
- [5] 2024. The EU AI Act. <https://artificialintelligenceact.eu/>
- [6] Andrick Adhikari, Sanchari Das, and Rinku Dewri. 2025. Natural Language Processing of Privacy Policies: A Survey. *CoRR* abs/2501.10319 (2025). doi:10.48550/ARXIV.2501.10319
- [7] Benjamin Andow, Samin Yaseer Mahmud, Wenyu Wang, Justin Whitaker, William Enck, Bradley Reaves, Kapil Singh, and Tao Xie. 2019. PolicyLint: Investigating Internal Privacy Policy Contradictions on Google Play. In *28th USENIX Security Symposium (USENIX Security 19)*. 585–602.
- [8] Adrien Barbaresi. 2024. Trafilatura. <https://pypi.org/project/trafilatura/>.
- [9] Shmuel I Becher and Uri Benoliel. 2020. Law in Books and Law in Action: The Readability of Privacy Policies and the GDPR. In *Consumer law and economics*. Springer, 179–204.
- [10] Asia J Biega, Peter Potash, Hal Daumé, Fernando Diaz, and Michèle Finck. 2020. Operationalizing the Legal Principle of Data Minimization for Personalization.

- In *Proceedings of the 43rd International ACM SIGIR Conference on Research and Development in Information Retrieval*. 399–408.
- [11] Duc Bui, Yuan Yao, Kang G Shin, Jong-Min Choi, and Junbum Shin. 2021. Consistency Analysis of Data-Usage Purposes in Mobile Apps. In *Proceedings of the 2021 ACM SIGSAC Conference on Computer and Communications Security*. 2824–2843.
 - [12] Jianlv Chen, Shitao Xiao, Peitian Zhang, Kun Luo, Defu Lian, and Zheng Liu. 2024. BGE M3-Embedding: Multi-Lingual, Multi-Functionality, Multi-Granularity Text Embeddings Through Self-Knowledge Distillation. *CoRR* abs/2402.03216 (2024). doi:10.48550/ARXIV.2402.03216
 - [13] Hao Cui, Rahmadi Trimananda, Athina Markopoulou, and Scott Jordan. 2023. PoliGraph: Automated Privacy Policy Analysis using Knowledge Graphs. In *32nd USENIX Security Symposium (USENIX Security 23)*. 1037–1054.
 - [14] Wenqi Fan, Yajuan Ding, Liangbo Ning, Shijie Wang, Hengyun Li, Dawei Yin, Tat-Seng Chua, and Qing Li. 2024. A Survey on RAG Meeting LLMs: Towards Retrieval-Augmented Large Language Models. In *Proceedings of the 30th ACM SIGKDD Conference on Knowledge Discovery and Data Mining*. 6491–6501.
 - [15] Prakhar Ganesh, Cuong Tran, Reza Shokri, and Ferdinando Fioretto. 2025. The Data Minimization Principle in Machine Learning. In *Proceedings of the 2025 ACM Conference on Fairness, Accountability, and Transparency*. 3075–3093.
 - [16] Yunfan Gao, Yun Xiong, Xinyu Gao, Kangxiang Jia, Jinliu Pan, Yuxi Bi, Yi Dai, Jiawei Sun, Qianyu Guo, Meng Wang, and Haofen Wang. 2023. Retrieval-Augmented Generation for Large Language Models: A Survey. *CoRR* abs/2312.10997 (2023). doi:10.48550/ARXIV.2312.10997
 - [17] Google. 2025. Google Play Store Categories. <https://developers.apptweak.com/reference/google-play-store-categories>
 - [18] Rujun Han, Yuhao Zhang, Peng Qi, Yumo Xu, Jinyuan Wang, Lan Liu, William Yang Wang, Bonan Min, and Vittorio Castelli. 2024. RAG-QA Arena: Evaluating Domain Robustness for Long-form Retrieval Augmented Question Answering. In *Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing*. 4354–4374.
 - [19] Luheng He, Kenton Lee, Mike Lewis, and Luke Zettlemoyer. 2017. Deep Semantic Role Labeling: What Works and What's Next. In *Proceedings of the 55th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*. 473–483.
 - [20] Lei Huang, Weijiang Yu, Weitao Ma, Weihong Zhong, Zhangyin Feng, Haotian Wang, Qianglong Chen, Weihua Peng, Xiaocheng Feng, Bing Qin, and Ting Liu. 2025. A Survey on Hallucination in Large Language Models: Principles, Taxonomy, Challenges, and Open Questions. *ACM Transactions on Information Systems* 43, 2 (2025), 1–55.
 - [21] Harshvardhan J. Pandit, Beatriz Esteves, Georg P. Krog, Paul Ryan, Delaram Golpayegani, and Julian Flake. 2024. Data Privacy Vocabulary (DPV)–Version 2.0. In *International Semantic Web Conference*. 171–193.
 - [22] Mingyu Jo. 2024. Google-play-scraper. <https://pypi.org/project/google-play-scraper/>.
 - [23] Mohammed Abdul Khaliq, Paul Yu-Chun Chang, Mingyang Ma, Bernhard Pflugfelder, and Filip Miletic. 2024. RAGAR, Your Falsehood RADAR: RAG-Augmented Reasoning for Political Fact-Checking using Multimodal Large Language Models. In *Proceedings of the Seventh Fact Extraction and Verification Workshop (FEVER)*. 280–296.
 - [24] Dawei Li, Bohan Jiang, Liangjie Huang, Alimohammad Beigi, Chengshuai Zhao, Zhen Tan, Amrita Bhattacharjee, Yuxuan Jiang, Canyu Chen, Tianhao Wu, Kai Shu, Lu Cheng, and Huan Liu. 2025. From Generation to Judgment: Opportunities and Challenges of LLM-as-a-judge. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing*. 2757–2791.
 - [25] Jiaqi Li, Mengmeng Wang, Zilong Zheng, and Muhan Zhang. 2024. LooGLE: Can Long-Context Language Models Understand Long Contexts?. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics*, Vol. 1. 16304–16333.
 - [26] Thomas Linden, Rishabh Khandelwal, Hamza Harkous, and Kassem Fawaz. 2020. The Privacy Policy Landscape After the GDPR. *Proceedings on Privacy Enhancing Technologies* 1 (2020), 47–64.
 - [27] Yuxi Ling, Yun Hao, Yuyan Wang, Kailong Wang, Guangdong Bai, and Jin Song Dong. 2024. Essential or Excessive? MINDAEXT: Measuring Data Minimization Practices among Browser Extensions. In *2024 IEEE International Conference on Software Analysis, Evolution and Reengineering (SANER)*. 964–975.
 - [28] Nelson F Liu, Kevin Lin, John Hewitt, Ashwin Paranjape, Michele Bevilacqua, Fabio Petroni, and Percy Liang. 2024. Lost in the Middle: How Language Models Use Long Contexts. *Transactions of the Association for Computational Linguistics* 12 (2024), 157–173.
 - [29] Colleen McClain, Michelle Faverio, Monica Anderson, and Eugenie Park. 2023. How Americans View Data Privacy. *Pew Research Center* (2023).
 - [30] Abraham Mhaidli, Selin Fidan, An Doan, Gina Herakovic, Mukund Srinath, Lee Matheson, Shomir Wilson, and Florian Schaub. 2023. Researchers' Experiences in Analyzing Privacy Policies: Challenges and Opportunities. *Proceedings on Privacy Enhancing Technologies* 4 (2023), 287–305.
 - [31] Kimberly Milam and Antonio Gulli. 2025. Context Engineering: Sessions & Memory. <https://www.kaggle.com/whitepaper-context-engineering-sessions-and-memory>
 - [32] Kenneth Reitz. 2024. Requests. <https://pypi.org/project/requests/>.
 - [33] Stephen Roller, Douwe Kiela, and Maximilian Nickel. 2018. Hearst Patterns Revisited: Automatic Hyponym Detection from Large Text Corpora. In *Proceedings of the 56th Annual Meeting of the Association for Computational Linguistics (Volume 2: Short Papers)*. 358–363.
 - [34] Tanusree Sharma, Lin Kyi, Yang Wang, and Asia J Biega. 2024. "I'm not convinced that they don't collect more than is necessary": {User-Controlled} Data Minimization Design in Search Engines. In *33rd USENIX Security Symposium (USENIX Security 24)*. 2797–2812.
 - [35] Ronit Singal, Pransh Patwa, Parth Patwa, Aman Chadha, and Amitava Das. 2024. Evidence-backed Fact Checking using RAG and Few-Shot In-Context Learning with LLMs. In *Proceedings of the Seventh Fact Extraction and Verification Workshop (FEVER)*. 91–98.
 - [36] Shamane Siriwardhana, Rivindu Weerasekera, Elliott Wen, Tharindu Kalurachchi, Rajib Rana, and Suranga Nanayakkara. 2023. Improving the Domain Adaptation of Retrieval Augmented Generation (RAG) Models for Open Domain Question Answering. *Transactions of the Association for Computational Linguistics* 11 (2023), 1–17.
 - [37] Robin Staab, Nikola Jovanovic, Kimberly Mai, Prakhar Ganesh, Martin T. Vechev, Ferdinando Fioretto, and Matthew Jagielski. 2025. SoK: Data Minimization in Machine Learning. *CoRR* abs/2508.10836 (2025). doi:10.48550/ARXIV.2508.10836
 - [38] Zeya Tan and Wei Song. 2023. PTPDroid: Detecting Violated User Privacy Disclosures to Third-Parties of Android Apps. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*. 473–485.
 - [39] Chenhao Tang, Zhengliang Liu, Chong Ma, Zihao Wu, Yiwei Li, Wei Liu, Dajiang Zhu, Quanzheng Li, Xiang Li, Tianming Liu, and Lei Fan. 2023. PolicyGPT: Automated Analysis of Privacy Policies with Large Language Models. *CoRR* abs/2309.10238 (2023). doi:10.48550/ARXIV.2309.10238
 - [40] Jenny Tang, Hannah Shoemaker, Ada Lerner, and Eleanor Birrell. 2021. Defining Privacy: How Users Interpret Technical Terms in Privacy Policies. *Proceedings on Privacy Enhancing Technologies* 3 (2021), 1–25.
 - [41] David Rodriguez Torrado, Ian Yang, José M. del Álamo, and Norman Sadeh. 2024. Large Language Models: A New Approach for Privacy Policy Analysis at Scale. *Computing* 106, 12 (2024), 3879–3903.
 - [42] Shenao Wang, Yanjie Zhao, Kailong Wang, and Haoyu Wang. 2023. On the Usage-scenario-based Data Minimization in Mini Programs. In *Proceedings of the 2023 ACM Workshop on Secure and Trustworthy Superapps*. 29–32.
 - [43] Xinyu Wang, Jijun Chi, Zhenghan Tai, Tung Sum Thomas Kwok, Hailin He, Zhihong Li, Yuchen Hua, Muzhi Li, Peng Lu, Suyuchen Wang, Yihong Wu, Jerry Huang, Jingrui Tian, Fengran Mo, Yufei Cui, and Ling Zhou. 2025. FinSage: A Multi-aspect RAG System for Financial Filings Question Answering. In *Proceedings of the 34th ACM International Conference on Information and Knowledge Management*. 6144–6152.
 - [44] Yue Xiao, Zhengyi Li, Yue Qin, Xiaolong Bai, Jiale Guan, Xiaojing Liao, and Luyi Xing. 2023. Lalaine: Measuring and Characterizing Non-Compliance of Apple Privacy Labels. In *32nd USENIX Security Symposium (USENIX Security 23)*. 1091–1108.
 - [45] Fuman Xie, Chuan Yan, Mark Huasong Meng, Shaoming Teng, Yanjun Zhang, and Guangdong Bai. 2024. Are Your Requests Your True Needs? Checking Excessive Data Collection in VPA Apps. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*. 1–12.
 - [46] Qinge Xie, Karthik Ramakrishnan, and Frank Li. 2025. Evaluating Privacy Policies under Modern Privacy Laws At Scale: An LLM-Based Automated Approach. In *34th USENIX Security Symposium (USENIX Security 25)*. 5797–5816.
 - [47] Jiayi Ye, Yanbo Wang, Yue Huang, Dongping Chen, Qihui Zhang, Nuno Moniz, Tian Gao, Werner Geyer, Chao Huang, Pin-Yu Chen, Nitesh V. Chawla, and Xiangliang Zhang. 2025. Justice or Prejudice? Quantifying Biases in LLM-as-a-Judge. In *The Thirteenth International Conference on Learning Representations*.
 - [48] Yuxia Zhan, Yan Meng, Lu Zhou, and Haojin Zhu. 2023. Vetting Privacy Policies in VR: A Data Minimization Principle Perspective. In *IEEE INFOCOM 2023-IEEE Conference on Computer Communications Workshops (INFOCOM WKSHPS)*. 1–2.
 - [49] Shaokun Zhang, Hanwen Lei, Yuanpeng Wang, Ding Li, Yao Guo, and Xiangqun Chen. 2023. How Android Apps Break the Data Minimization Principle: An Empirical Study. In *2023 38th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. 1238–1250.
 - [50] Yaowei Zheng, Richong Zhang, Junhao Zhang, YeYanhan YeYanhan, and Zheyang Luo. 2024. LlamaFactory: Unified Efficient Fine-Tuning of 100+ Language Models. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics*, Vol. 3. 400–410.
 - [51] Lu Zhou, Chengyongxiao Wei, Tong Zhu, Guoxing Chen, Xiaokuan Zhang, Suguo Du, Hui Cao, and Haojin Zhu. 2023. {POLICYCOMP}: Counterpart Comparison of Privacy Policies Uncovers Overbroad Personal Data Collection Practices. In *32nd USENIX Security Symposium (USENIX Security 23)*. 1073–1090.
 - [52] Sebastian Zimmeck, Ziqi Wang, Lieyong Zou, Roger Iyengar, Bin Liu, Florian Schaub, Shomir Wilson, Norman M. Sadeh, Steven M. Bellovin, and Joel R. Reidenberg. 2017. Automated Analysis of Privacy Requirements for Mobile Apps. In *24th Annual Network and Distributed System Security Symposium*.